

Executive Cybersecurity Program Overview

Simulated e-commerce security transformation case study

Business Context

Botium Toys is used here as a fictional portfolio scenario representing a growing e-commerce company with cloud-hosted customer applications, employee endpoints, identity services, payment processing, SaaS integrations, and distributed business operations. The objective is to create a coordinated security program that reduces risk while supporting growth.

Executive Risk Summary

Priority	Risk	Business impact	Primary treatment	Residual target
1	Privileged-account compromise	Unauthorized administrative access, data exposure, service disruption	Phishing-resistant MFA, least privilege, privileged reviews, admin logging	Medium
2	Critical internet-facing vulnerabilities	Application compromise, downtime, customer-data exposure	Asset ownership, 7-day critical SLA, scanning, emergency patch path, validation	Medium
3	Incomplete centralized logging	Delayed detection, weak incident evidence, poor auditability	SIEM onboarding standard, required log sources, retention, alert ownership	Medium
4	Ransomware / recovery failure	Extended outage, data loss, business interruption	EDR, segmentation, immutable backups, restore testing, IR playbooks	Medium
5	Weak access governance	Excess access, orphan accounts, service-account misuse	RBAC, JML process, quarterly reviews, service-account ownership	Medium
6	Phishing / credential theft	Account compromise, fraud, mailbox/cloud misuse	MFA, email controls, awareness, risky-sign-in detection, rapid session revocation	Medium

Program Objectives

- Protect customer and employee identities using MFA, least privilege, access reviews, and secure joiner/mover/leaver processes.
- Reduce attack surface through vulnerability management, secure configuration, and controlled administrative access.
- Improve detection through centralized logs, practical SIEM detections, dashboards, and clear alert ownership.
- Standardize incident response through severity criteria, playbooks, evidence handling, escalation, and post-incident corrective actions.
- Improve recovery confidence through tested backups, documented RTO/RPO, and restore validation.
- Create control evidence that supports NIST, ISO, SOC 2, PCI DSS, and GDPR readiness without overstating formal compliance.

Top 90-Day Outcomes

- 100% of privileged identities in the simulated scope covered by strong MFA and quarterly recertification.
- All critical internet-facing assets assigned to owners and measured against a 7-day critical vulnerability SLA.
- Identity, endpoint, firewall, WAF, application, and cloud audit logs prioritized for central monitoring.
- Tier 1 SOC runbooks and incident-severity matrix implemented for authentication, phishing, endpoint, and availability alerts.
- Quarterly restore testing scheduled with evidence retained.
- Security dashboard established for executive and operational reporting.